

[doc. web n. 10037411]
Decision of June 20, 2024
Register of Decisions
n. 378 of June 20, 2024

THE GUARANTOR FOR THE PROTECTION OF PERSONAL DATA

IN the meeting held today, attended by
Prof. Pasquale Stanzione, President, Prof.
Ginevra Cerrina Feroni, Vice President, Dr.
Agostino Ghiglia, and Attorney Guido Scorza, members, and
Counsel Fabio Mattei, Secretary General;

HAVING REGARD TO Regulation (EU) 2016/679 of the European Parliament
and of the Council, of April 27, 2016, on the protection of natural persons with regard to the processing
of personal data, as well as the free movement of such data and repealing Directive 95/46/EC,
“General Data Protection Regulation” (hereinafter “Regulation”);

HAVING REGARD TO Legislative Decree No. 196 of June 30, 2003, containing the “Code regarding
the protection of personal data, containing provisions for the adaptation of the national legal system to
Regulation (EU) 2016/679 of the European Parliament and of the Council, of April 27, 2016, on the
protection of natural persons with regard to the processing of personal data, as well as the free
movement of such data and repealing Directive 95/46/EC” (hereinafter “Code”);

HAVING REGARD TO Regulation No. 1/2019 concerning internal procedures with external relevance,
aimed at carrying out the tasks and exercising the powers assigned to the Guarantor for the protection
of personal data, approved by resolution No. 98 of April 4, 2019, published in G.U. No. 106 of May 8,
2019 and on www.gpdp.it, doc. web n. 9107633 (hereinafter “Guarantor Regulation No. 1/2019”);

HAVING REGARD TO the documentation on file;

HAVING REGARD TO the observations made by the Secretary General pursuant to Article 15 of
Guarantor Regulation No. 1/2000 on the organization and functioning of the office of the Guarantor for
the protection of personal data, on www.gpdp.it, doc. web n. 1098801;

REPORTING Attorney Guido Scorza;

PREMISED

1. The Complaint

With a complaint submitted to the Authority on XX, Ms. XX, through her lawyer, complained that she
had exercised, on XX, her right of access to her personal data pursuant to Article 15 of the Regulation,
in order to access the pre-operative photographs related to a procedure performed by the
aforementioned professional on XX, at the healthcare facility XX located in XX, and that she had not
received a response.

2. The Investigative Activity

Following this complaint, the Office, with a note dated XX (prot. n. XX), invited XX and Dr. XX to
comply - pursuant to Article 15 of Guarantor Regulation No. 1/2019 (doc. web n. 9107633) - with the
requests of the complainant.

In response to this invitation, XX provided feedback with a note dated XX, while Dr. XX responded with
a note dated XX, simultaneously informing the undersigned Authority.

In particular, the latter, in the response sent, along with the requested pre-operative photographs,
represented that:

- “On the same morning of the surgical procedure, but prior to it, I, acting entirely independently,
expressly instructed my assistant surgeon (...) to take - as is customary - some photographs of the
body of the aforementioned patient: aside from the purposes indicated in the consent and
authorizations granted, the primary purpose of such photographic images is their intra-operative use,
that is to allow the operating surgeon, or myself, to view the image of the part of the patient’s body

'pre-operation', when the patient is in the so-called 'closure'";

- "(...) during the same morning, these photographs were handed over to me by the aforementioned (...) (assistant surgeon) who (...) was merely executing a specific task assigned to him by me and therefore was responsible for processing any personal data";
- "For the above reasons, the decision to collect the data was exclusively mine, and therefore, regarding the processing activity, no responsibility can be attributed (to others)";
- "These photographic images did not depict the patient's face, but exclusively the part of the body relevant to the surgical procedure (in this case, the abdomen)";
- "On XX, on behalf of Ms. XX, (the trusted lawyer) transmitted, among many other grievances, requests, warnings, and compensation claims, all sent with numerous additional certified emails over a short period, a request for the photographs taken prior to the execution of the procedure";
- "(...) (to) me, after (...) 1 year and 5 months from the procedure, the retrieval of such photographic images proved extremely complicated, precisely because they were photographs, not depicting the face, not immediately attributable to the patient (...)";
- "In the meantime, during this search, the (...) (complainant) filed a petition for preventive technical assessment before the Ordinary Court of Velletri aimed at crystallizing, through a technical medical-legal consultancy, an alleged physiognomic damage suffered as a result of the surgical procedure performed by me, to which responsibility was allegedly attributed."

1. "medical error";

- "the undersigned, although having himself, before anyone else, (...) (intended) to deposit in Court the 'pre-operative' photographs of the patient (these would have constituted further confirmation of the unfoundedness of Ms. XX's claims), was unfortunately unable to do so due to the futile outcome of the search (fortunately, there were nonetheless sufficient elements to refute the claims and demands of the complainant XX: as evidenced by the preliminary report of the Court Consultant who currently denies any medical error)";
- "(...) regrets not having been able to obtain the requested material in a timely manner but, as already mentioned, the non-direct and immediate traceability of certain images, and not others of other subjects, to Ms. XX, combined with the subsequent need to defend oneself in the legal dispute initiated by the aforementioned, and also coupled with the time spent and the distraction of having been the recipient of numerous certified emails (...) (from the complainant's lawyer), have resulted in the almost impossibility of satisfying the request";
- "after a strenuous search, the photographs taken before the surgical intervention, depicting only the body of the patient corresponding to the name XX, have been obtained and are therefore attached to this document (in compressed format for telematic transmission) sent to the only certified email address of the complainant's legal representative (...) (patient)".

Following the above-mentioned responses, the Office, with a note dated XX (prot. no. XX), in order to make definitive determinations regarding the procedure opened following the complaint in question, invited the complainant to formulate any observations regarding the response provided.

With a note dated XX, the complainant, through their lawyer, submitted their observations, highlighting, in particular, the time elapsed between the date of the request and the date of delivery of the aforementioned photographs - with prejudicial impossibility of producing them in the ongoing proceedings against the doctor.

Based on the above, the Office, in light of the reports and the articulation of the privacy roles between XX and Dr. XX - the author of the intervention to which the data concerning the requested pre-operative photographs refer - as well as in light of the concrete circumstances of the processing, ordered the archiving against the aforementioned healthcare facility and requested, with a note dated XX (prot. no. XX), the aforementioned doctor, as the data controller of the complainant's data, to provide - pursuant to Article 157 of the Code - any useful information regarding the above-represented matter, within 30 days from the receipt of the note, in order to complete the investigation of the request made by the complainant.

On XX, the data controller responded to the Authority's request, stating, among other things, that:

"Firstly (...) it is untrue and entirely instrumental on the part of the complainant to classify the unavailability of the photographic documentation in question in a timely manner for the technical assessment procedure, which has now concluded before the ordinary judge, as 'prejudicial': this documentation instead constitutes proof and confirmation of the unfoundedness of the alleged medical error";

"Secondly, regarding the information referred to in Article 13 of the Regulation, (...) it was and is posted and clearly visible in the medical office (...) in XX where the undersigned carries out his professional medical activity extramurally (...) and therefore where the (...) (patient) underwent pre-operative visits and post-operative checks. To prove this last circumstance (...) a copy of the aforementioned information is provided along with a signed declaration (by two employees of the office (...)), as well as a photographic image depicting the presence of the information itself within the aforementioned premises."

3. Evaluations of the Department on the processing carried out and notification of the violation referred to in Article 166, paragraph 5, of the Code

In relation to the documentation on file and what was declared by the data controller, the Office, with an act dated XX (prot. no. XX), initiated, pursuant to Article 166, paragraph 5, of the Code, the procedure for the adoption of measures referred to in Article 58, paragraph 2 of the Regulation against Dr. XX, as the data controller, inviting him to produce to the Authority defensive writings or documents, or to request to be heard by the Authority (Article 166, paragraphs 6 and 7, of the Code, as well as Article 18, paragraph 1, Law No. 689 of November 24, 1981).

Following what emerged, the Office deemed that the aforementioned doctor processed the complainant's personal data in violation of the regulations regarding personal data. In particular, it was noted that Dr. XX did not respond to the request to exercise the rights of the data subject within the terms provided for by Article 12 in relation to Article 15 of the Regulation, but only following the invitation to comply with the complainant's requests, made pursuant to Article 15 of Regulation No. 1/2019 of the Authority for the protection of personal data (doc. web no. 9107633) and did not comply with the transparency obligations due to insufficient indication of the data retention period to be provided to the data subjects (Article 13, paragraph 2, letter a) of the Regulation).

4. Outcome of the investigative activity

Following the contested act dated XX (prot. no. XX), considering that the data controller did not exercise the right to produce defensive writings or documents and to be heard by the Authority (Article 166, paragraphs 6 and 7, of the Code, as well as Article 18, paragraph...

1. Law No. 689 of November 24, 1981), taking into account all that has been represented in the documents and declared, the following is observed.

4.1 Lack of response to the request for the exercise of rights (Article 12, paragraph 3, in relation to Article 15 of the Regulation)

With reference to the issue raised, it is highlighted that "personal data" means "any information relating to an identified or identifiable natural person ('data subject')" and "data concerning health" means "personal data related to the physical or mental health of a natural person, including the provision of health care services, which reveal information concerning their health status" (Article 4, paragraph 1, items 1 and 15 of the Regulation).

In these latter cases, "(...) all data concerning the health status of the data subject that reveal information related to their past, present, or future physical or mental health should be included. This includes information about the natural person collected during their registration to receive health care services (...); a number, symbol, or specific element assigned to a natural person to uniquely identify them for health purposes; information resulting from examinations and checks carried out on a part of the body or a biological substance, including genetic data and biological samples; and any information concerning, for example, a disease, a disability, the risk of diseases, medical history, clinical treatments, or the physiological or biomedical status of the data subject, regardless of the source, such as, for example, a doctor or other health care provider, a hospital, a medical device, or an in vitro diagnostic test" (Recital 35).

These latter data deserve greater protection since the context of their processing could create significant risks to the rights and fundamental freedoms (Recital No. 51).

In this circumstance, the complainant, through the exercise of the right of access to data pursuant to Article 15 of the Regulation, requested a copy of the preoperative photographs, which, according to the consolidated orientation of the Authority (see decisions of the Guarantor since 2002, in Bulletin No. 28, page 34 - web document 1064753), as well as according to what is provided in the aforementioned Recital 35 of the Regulation, constitute personal data, in this case related to health.

Regarding information, communications, and transparent methods for the exercise of the rights of the data subject, Article 12, paragraph 3, of the Regulation establishes that the data controller must respond to the request of the data subject, made in this case pursuant to Article 15 of the Regulation, without undue delay and, in any case, no later than one month from receipt of the request. This term may be extended by two months, if necessary, taking into account the complexity and number of requests, provided that the data subject is informed of such extension and the reasons for the delay within one month from receipt of the request.

If the data controller does not comply with the request of the data subject, they must, in any case, inform the data subject without delay and, at the latest, within one month from receipt of the request, of the reasons for non-compliance and the possibility of lodging a complaint with a supervisory authority and of seeking judicial remedy (Recital 59 and Article 12, paragraph 4, of the Regulation).

Based on the elements acquired following the investigative activity, as well as the subsequent evaluations of this Department regarding the matter complained of by the complainant, it has been established that Dr. XX, in relation to the request to provide a copy of their personal data consisting of preoperative photographs, did not respond to the request made by the interested party pursuant to Article 15 of the Regulation, within the terms provided by Article 12 of the same Regulation.

Specifically, in response to the request made by the interested party on XX, the data controller provided a response only following the aforementioned invitation to comply with the requests of the complainant, sent by the Authority itself, with a note dated XX, that is, after 302 days from the date of the interested party's request.

4.2 Non-compliance with transparency obligations due to insufficient indication in the information referred to in Article 13 of the Regulation regarding the data retention period to be provided to data subjects (Article 13, paragraph 2, letter a) of the Regulation)

The data controller, in the case of collecting - from the data subject - the data concerning them, is required to provide the latter, at the time when such personal data are obtained, with the information required by Article 13 of the Regulation.

In particular, the data controller must provide, among other things, "(...) the period for which the personal data will be stored, or, if that is not possible, the criteria used to determine that period" (Article 13, paragraph 2, letter a) of the Regulation). This obligation does not exist only if, and to the extent that, the data subject already has the information (Article 13, paragraph 4).

With reference to the information to be provided to the data subject within the activities carried out by data controllers operating in the health sector, if "(...) the retention periods for specific health documents are not established by a legal provision, the data controller, by virtue of the accountability principle, must determine that period so that the data are retained, in a form which permits identification of the data subjects, for no longer than is necessary for the purposes for which the data are processed (principle of data retention limitation, Article 5, paragraph 1, e) of the Regulation) and indicate such period (or the criteria for determining it) among the information to be provided to the data subject" (see also paragraph 2 of the Provision of March 7, 2019, no. 55, web document no. 9091942, titled "Clarifications on the application of the regulation for the processing of health-related data in the healthcare sector").

In the same vein, according to what is indicated in the Annex to the Guidelines on transparency pursuant to Regulation 2016/679 - developed by the Article 29 Working Party and adopted on November 29, 2017, as well as, in the amended version, on April 11, 2018 (WP260 rev.01) - titled "Information to be provided to the data subject pursuant to Articles 13 or 14", the retention period (or the criteria for determining it) "should be indicated in such a way as to allow the data subject to

establish what the period will be, based on their specific situation, for the specific data/purposes. It is not sufficient for the data controller to generically state that personal data will be retained as long as necessary for the legitimate purposes of processing. Where relevant, different retention periods should be established for different categories of personal data and/or purposes of processing, including, where applicable, archiving periods.”

From the examination of the documentation on file, in the text of the copy of the information provided by the data controller, titled “Information on the processing of personal data pursuant to and for the purposes of Articles 13 and 14 of EU Regulation 2016/679 ‘GDPR Regulation’”, it is indicated, with reference to the retention period of personal data, that “The Personal Data of the Data Subject will be retained only for the time necessary for the purposes for which they are collected, in compliance with the principle of minimization set out in Article 5, paragraph 1, letter c) of the GDPR as well as the legal obligations to which the Controller is subject.” In this regard, it is represented that, in light of the provisions on personal data protection mentioned above, such indications do not fulfill the requirement contained in Article 13, paragraph 2, letter a) of the Regulation (according to which information on the retention period of data may also be provided by the controller through the indication of the criteria used to determine it) due to the generality of the formulation used.

5. Conclusions.

Based on the evaluations mentioned above, taking into account the statements made by the data controller during the investigation and considering that, unless the act constitutes a more serious offense, anyone who, in a proceeding before the Authority, falsely declares or certifies information or circumstances or produces false acts or documents, is liable under Article 168 of the Code “Falsehood in declarations to the Authority and interruption of the execution of the tasks or exercise of the powers of the Authority” - also considering that the data controller, as mentioned above, did not avail themselves of the opportunity to produce defensive writings or documents, nor to be heard by the Authority - none of the cases provided for in Article 11 of the Authority’s Regulation no. 1/2019 applies. Therefore, all that has been stated, based on the current state of the acts and the statements provided, in relation to the matter in question, it is established that Dr. XX, the data controller, processed the data of the complainant in the matter in question:

- in violation of Article 12, in relation to Article 15 of the Regulation, for failing to provide feedback, within the terms set by Article 12 of the Regulation, to the request to exercise the right of access to data made by the complainant on XX. Such feedback was provided on XX following the invitation to comply with the requests of the complainant made by the writing Authority;
- in violation of Article 13, paragraph 2, letter a) of the Regulation, for failing to identify in the document “Information on the processing of personal data pursuant to and for the purposes of Articles 13 and 14 of EU Regulation 2016/679 ‘GDPR Regulation’”, the retention periods of the personal data processed or the criteria for determining them, given the general formulation adopted therein.

6. Corrective measures (Article 58, paragraph 2, letter d), of the Regulation).

Article 58, paragraph 2, letter d), of the Regulation provides that the Authority has the corrective powers to “order the data controller or the processor to bring processing into compliance with the provisions of this Regulation, if necessary, in a specific manner and within a specific timeframe.” In this context, in light of the indicated norms, it is deemed necessary to order, pursuant to the aforementioned provision, that Dr. XX, due to the incompleteness of the information present in the information provided to patients regarding the retention period of personal data referred to in Article 13, paragraph 2, letter a) of the Regulation, supplement such information by identifying the retention period of the personal data or the criteria used to determine it, in compliance with the principle of data retention limitation set out in Article 5, paragraph 1, letter e) of the Regulation. Conversely, regarding the violation concerning the failure to respond to the request for access to their personal data under Articles 12 in relation to Article 15 of the Regulation, considering that the delivery of a copy of the personal data consisting of the preoperative photographs requested by the complainant occurred on XX, and that such conduct has exhausted its effects, the conditions for the adoption of further corrective measures under Article 58, paragraph 2, of the Regulation do not apply.

7. Adoption of the injunction order for

****Application of the Administrative Monetary Sanction and Accessory Sanctions (Articles 58, paragraph 2, letter i and 83 of the Regulation; Article 166, paragraph 7, of the Code). ****

The violation of Article 12, paragraph 3, in relation to Article 15 of the Regulation and Article 13, paragraph 2, letter a) of the same Regulation, caused by the conduct carried out by the data controller, is subject to the application of the administrative monetary sanction pursuant to Article 83, paragraph 5, letter b) of the Regulation and Article 166, paragraph 2, of the Code.

The Guarantor, pursuant to Articles 58, paragraph 2, letter i) and 83 of the Regulation, as well as Article 166 of the Code, has the power to “impose an administrative monetary sanction pursuant to Article 83, in addition to [other] corrective measures [provided for] in this paragraph, or in lieu of such measures, depending on the circumstances of each individual case” and, in this context, “the Board [of the Guarantor] adopts the injunction order, which also provides for the application of the accessory administrative sanction of its publication, in whole or in part, on the Guarantor's website pursuant to Article 166, paragraph 7, of the Code” (Article 16, paragraph 1, of the Guarantor's Regulation No. 1/2019).

The aforementioned administrative monetary sanction imposed, depending on the circumstances of each individual case, must be determined in amount taking into account the principles of effectiveness, proportionality, and deterrence, as indicated in Article 83, paragraph 1, of the Regulation.

First of all, considering that the violations related to the matter in question fall within the categories listed in Article 83, paragraph 5, letter b) of the Regulation, the total amount of the sanction is to be quantified up to 20,000,000 euros (maximum so-called “static” amount).

Regarding the assessment of the severity of the violation (Article 83, paragraph 2, letters a), b), and g) of the Regulation), it is believed that the level of severity is to be considered low, as it was an isolated case and in the absence of intent, and it is taken into account that the matter concerned data related to the health of only one affected individual.

In relation to the assessment of the additional elements provided for by Article 83, paragraph 2 of the Regulation, such as aggravating and mitigating circumstances, it is noted that:

- no previous measures concerning relevant violations have been adopted against the data controller, nor have any measures pursuant to Article 58 of the Regulation been previously ordered (Article 83, paragraph 2, letter e) of the Regulation);
- the data controller has fully cooperated with the Authority in all phases of the procedure (Article 83, paragraph 2, letter f) of the Regulation);
- the Authority became aware of the case in question following a complaint filed by the interested party (Article 83, paragraph 2, letter h) of the Regulation);

In light of the aforementioned elements, assessed as a whole, it is deemed appropriate to determine the amount of the monetary sanction provided for by Article 83, paragraph 5, of the Regulation, in the amount of 4,000.00 euros (four thousand/00) for the violation of Article 12, in relation to Article 15 and Article 13, paragraph 2, letter a) of the Regulation, as an administrative monetary sanction deemed, pursuant to Article 83, paragraph 1, of the Regulation, effective, proportionate, and deterrent.

It is also believed that the accessory sanction of publication on the Guarantor's website of this provision, as provided for by Article 166, paragraph 7, of the Code and Article 16 of the Guarantor's Regulation No. 1/2019, should be applied, considering the type of personal data involved in this matter and the fact that the violation concerns the rights of the interested parties.

Finally, it is noted that the conditions set forth in Article 17 of Regulation No. 1/2019 concerning internal procedures with external relevance, aimed at carrying out the tasks and exercising the powers entrusted to the Guarantor, are met.

****THEREFORE, THE GUARANTOR****

declares the unlawfulness of the processing of personal data carried out by Dr. XX, born in XX on XX

and belonging to the Order of Surgeons and Dentists of XX, Tax Code: XX for the violation of Article 12, paragraph 3, in relation to Article 15 of the Regulation and Article 13, paragraph 2, letter a) of the same Regulation as stated in the reasoning;

****ORDERS****

pursuant to Articles 58, paragraph 2, letter i) and 83 of the Regulation, as well as Article 166 of the Code, the aforementioned data controller to pay the sum of 4,000.00 euros (four thousand/00) as an administrative monetary sanction for the violations indicated in this provision; it is represented that the violator, pursuant to Article 166, paragraph 8, of the Code, has the option to settle the dispute by paying, within 30 days, an amount equal to half of the imposed sanction.

****ORDERS****

the aforementioned data controller, in the event of failure to settle the dispute pursuant to Article 166, paragraph 8, of the Code, to pay the sum of 4,000.00 (four thousand) according to the methods indicated in the attachment, within 30 days from the notification of this provision, under penalty of the adoption of subsequent enforcement acts in accordance with Article 27 of Law No. 689/1981;

pursuant to Article 58, paragraph 2, letter d), of the Regulation, to bring the processing into compliance with the provisions of the Regulation, adopting within 40 days from the notification of this provision, the corrective measure of reworking the document.

referred to as "Information on the processing of personal data pursuant to and for the purposes of Articles 13 and 14 of EU Regulation 2016/679 'GDPR Regulation', providing to integrate the information regarding the retention period of personal data referred to in Article 13, paragraph 2, letter a), identifying such period or the criteria used to determine it, in compliance with the principle of data retention limitation as per Article 5, paragraph 1, letter e) of the Regulation. The failure to comply with an order issued pursuant to Article 58, paragraph 2, of the Regulation is punishable by the administrative sanction referred to in Article 83, paragraph 6, of the Regulation; pursuant to Article 58, paragraph 1, letter a), of the Regulation and Article 157 of the Code, to communicate what initiatives have been undertaken in order to implement the provisions (in paragraph 6 and in the operative part) and to provide a documented response, adequately substantiated, within and no later than 20 days from the expiration of the aforementioned 40-day period. The failure to respond to a request made pursuant to Article 157 of the Code is punishable by the administrative sanction, pursuant to the combined provisions of Articles 83, paragraph 5, of the Regulation and 166 of the Code.

ORDERS

pursuant to Article 166, paragraph 7, of the Code, the full publication of this provision on the website of the Authority and considers that the conditions referred to in Article 17 of Regulation No. 1/2019 concerning internal procedures with external relevance, aimed at carrying out the tasks and exercising the powers entrusted to the Authority, are met.

Pursuant to Article 78 of the Regulation, Articles 152 of the Code, and Article 10 of Legislative Decree No. 150/2011, against this provision it is possible to appeal to the ordinary judicial authority, under penalty of inadmissibility, within thirty days from the date of communication of the provision itself or within sixty days if the appellant resides abroad.

Rome, June 20, 2024

THE PRESIDENT

Stanzione

THE RAPPORTEUR

Scorza

THE SECRETARY GENERAL

Mattei